

แนวปฏิบัติในการจัดทำเว็บไซต์มหาวิทยาลัยสงขลานครินทร์

พ.ศ. 2568 (เวอร์ชัน 1.3)

บันทึกการแก้ไข

แก้ไขครั้งที่	วันที่	รายละเอียด
1.0	22 เมษายน 2567	ฉบับออกใหม่
1.1	2 พฤษภาคม 2567	แก้ไข หน้า 4 ข้อ 4.เกณฑ์เปรียบเทียบ CIS Benchmarks แก้ไข หน้า 4 รายละเอียดแจ้งขอเปิดเว็บไซต์ เพิ่มข้อ 2. โดยมีผู้บริหารไอทีส่วนงานชื่อ...(ระบุชื่อ นามสกุล) แก้ไข หน้า 10 ภาคผนวก ง ข้อ 2 และ ข้อ 3 และเพิ่มข้อ ง3 Certificate Chain
1.2	20 มกราคม 2568	เพิ่ม ภาคผนวก ข. ตรวจสอบระบบปฏิบัติการ (Operating System : OS) ภาคผนวก ซ. ตรวจสอบการเผยแพร่ข้อมูลส่วนบุคคล
1.3	4 กุมภาพันธ์ 2568	เพิ่มเกณฑ์เปรียบเทียบ Security Scorecard แก้ไข รายละเอียด แจ้ง ขอเปิดเว็บไซต์ เพิ่ม กำหนดชื่อไฟล์หลักฐานประกอบ ภาคผนวก ก. ข. ค. ง. จ. ฉ. ซ. ช. ภาคผนวก ฉ. ตรวจสอบ Security Scorecard

วัตถุประสงค์

1. ผู้ดูแลเว็บไซต์ทราบขั้นตอน “ลงทะเบียนเว็บไซต์ ม.อ.”
2. ผู้ดูแลเว็บไซต์สามารถตรวจสอบความมั่นคงปลอดภัยทางไซเบอร์ของเว็บไซต์ที่รับผิดชอบในเบื้องต้นได้เอง ตามภาคผนวก
3. ผู้ดูแลเว็บไซต์ได้ทราบ “แนวปฏิบัติการรักษาความมั่นคงปลอดภัยเว็บไซต์ สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (สกมช.)”
4. ผู้ดูแลเว็บไซต์ได้ทราบ “รายละเอียดมาตรฐานเว็บไซต์ภาครัฐ เวอร์ชัน 3.0 ที่ออกเมื่อวันที่ 28 กันยายน 2566 สำนักงานพัฒนารัฐบาลดิจิทัล (องค์การมหาชน) (มสพร.)”
5. ผู้ดูแลเว็บไซต์ได้ทราบ “รายละเอียด รายงาน OVAL และเกณฑ์เปรียบเทียบ CIS Benchmarks โดย Center for Internet Security)”
6. ลดโอกาสที่เว็บไซต์ ม.อ. จะถูกโจมตี และระงับการเผยแพร่ข้อมูลส่วนบุคคลผ่านทางเว็บไซต์
7. ลดจำนวนหนังสือที่สำนักนวัตกรรมการผลิตและระบบอัจฉริยะต้องส่งแจ้งให้ส่วนงานในมหาวิทยาลัยแก้ไขช่องโหว่เว็บไซต์
8. เพิ่มจำนวนเว็บไซต์ภายใต้ชื่อโดเมนของ ม.อ. ที่ได้มาตรฐานเว็บไซต์ภาครัฐ

ขอบเขต

เว็บไซต์ ม.อ. คือ เว็บไซต์คณะ/ส่วนงานภายในมหาวิทยาลัยสงขลานครินทร์ ที่อยู่ภายใต้ชื่อโดเมนย่อย และภายใต้ชื่อโดเมน psu.ac.th และ psu.th

แนวปฏิบัติ มาตรฐาน และ เกณฑ์เปรียบเทียบ

1. แนวปฏิบัติการรักษาความมั่นคงปลอดภัยเว็บไซต์ (Website Security Guideline) สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (สกมช.) หัวข้อ มาตรฐานและแนวทางปฏิบัติ
<https://www.ncsa.or.th/standards-and-practices.html>
2. มาตรฐานเว็บไซต์ภาครัฐ เวอร์ชัน 3.0 วันที่ 28 กันยายน 2566 มสพร.11-2566
<https://standard.dga.or.th/wp-content/uploads/2023/09/มสพร.-11-2566-ว่าด้วยมาตรฐานเว็บไซต์ภาครัฐ-เวอร์ชัน-3.0.pdf>
3. มาตรฐานเว็บไซต์ภาครัฐ เวอร์ชัน 3.0 รายการตรวจสอบ (Checklist)

https://standard.dga.or.th/wp-content/uploads/2023/09/เอกสารประกอบเล่มมาตรฐานเว็บไซต์_Checklist_v0.1-1.pdf

4. เกณฑ์เปรียบเทียบ CIS Benchmarks ต่างๆ ที่ Center for Internet Security สำหรับส่วนประกอบต่างๆ ของเว็บไซต์
OS เช่น CentOS, Debian, Microsoft Windows Server, Oracle, Red Hat, Ubuntu
Server Software เช่น Apache HTTP, Apache Tomcat, BIND, Docker, Kubernetes, MariaDB, Microsoft IIS, Microsoft SQL Server, MongoDB, NGINX, Oracle Database, PostgreSQL, VMware
สำหรับอุปกรณ์เครือข่ายต่างๆ เช่น Cisco, Fortinet, Palo Alto Networks
สำหรับโปรแกรมเว็บเบราว์เซอร์ เช่น Edge, Google Chrome, Mozilla Firefox, Safari
สำหรับโปรแกรมต่างๆ เช่น Microsoft 365, Microsoft Office, Zoom
<https://www.cisecurity.org/cis-benchmarks>
5. เกณฑ์เปรียบเทียบ Security Scorecard จาก สกมช. โดยระบบ Proactive Cyber Watch (PCW)
รายงานสรุปภัยคุกคามทางไซเบอร์ของหน่วยงาน (ระบบ Attack Surface Management) โครงการระบบตรวจจับพฤติกรรมและวิเคราะห์ข้อมูลอาชญากรรมทางไซเบอร์เชิงรุกสำหรับหน่วยงาน
โครงสร้างพื้นฐานสำคัญ ทางสารสนเทศ และหน่วยงานภาครัฐ (รายละเอียดในภาคผนวก ณ.)
<https://securityscorecard.com/>

ขั้นตอนลงทะเบียนเว็บไซต์ ม.อ. (PSU Website Registration)

1. ผู้ดูแลเว็บไซต์ได้จัดทำเว็บไซต์ตาม “แนวปฏิบัติ มาตรฐาน และเกณฑ์เปรียบเทียบ” ข้างบนครบถ้วน
2. ผู้ดูแลเว็บไซต์อีเมลถึง itoc@psu.ac.th โดยระบุ ชื่อเรื่อง (Subject)

ขอเปิดเว็บไซต์ (ชื่อเว็บไซต์) ให้เข้าถึงได้จากอินเทอร์เน็ต

ในอีเมลให้แจ้งรายละเอียดดังต่อไปนี้

===== เริ่มต้น รายละเอียด แจ้ง ขอเปิดเว็บไซต์ =====

1. ข้าพเจ้าชื่อ...(ระบุชื่อ นามสกุล) เป็น ผู้ดูแลเว็บไซต์ (และ OS ของเครื่องแม่ข่าย) -> กรณีดูแลทั้งหมดโดยบุคคลเดียว
(โดยมี (ระบุชื่อ นามสกุล) ดูแล OS ของเครื่องแม่ข่าย -> กรณีแยกส่วนกันดูแล)
มีความประสงค์ขอเปิดเว็บไซต์ให้เข้าถึงได้จากอินเทอร์เน็ต

2. โดยมีผู้บริหารไอทีส่วนงานชื่อ...(ระบุชื่อ นามสกุล)
3. เว็บไซต์ชื่อ...(ระบุ URL ของเว็บไซต์ https://...)
4. ซึ่งเป็นเว็บไซต์ของส่วนงาน...(ระบุชื่อส่วนงาน และหน่วยงานย่อย)
5. IP Address... (ระบุ Private IP Address ของเครื่องที่มีเว็บไซต์นี้)
6. ข้าพเจ้ายืนยันว่า (ได้/ไม่ได้) ติดตั้งใบรับรองดิจิทัล (SSL Certificate) เพื่อรองรับ https port 443
7. นอกจาก port 80, 443 แล้ว ต้องการเปิดให้เข้าถึง port ต่อไปนี้ (ระบุเลข port เพิ่มเติม)
8. ข้าพเจ้ารับทราบว่า เว็บไซต์ที่ขอเปิด จะถูกตรวจสอบด้วย Nessus Vulnerability Scanner อย่างน้อยเดือนละครั้ง และเมื่อมีเหตุเกี่ยวกับความมั่นคงปลอดภัยของเว็บไซต์
9. ข้าพเจ้าเป็นผู้ดูแลรับผิดชอบในการแก้ไข ไม่ให้มีช่องโหว่ Critical, High, Medium ตามรายงาน Nessus ที่ได้รับ โดยให้รายละเอียดตามที่ใช้งานจริงสำหรับกำหนดค่าทำรายงาน Nessus เกี่ยวกับเว็บไซต์ดังนี้
 - 9ก. OS เป็นระบบ และ รุ่นใด?
 - 9ข. Web Server เป็นระบบ และ รุ่นใด?
 - 9ค. ติดตั้งระบบ Web Server และส่วนประกอบ อ้างอิง คำแนะนำจาก URL ใด?
10. หากโปรแกรมเว็บไซต์ใช้บน OS Linux ให้ส่ง หลักฐานประกอบการตรวจสอบ เป็นรายงาน OVAL ผ่านทางลิงก์ หรือไฟล์แนบมากับอีเมล ตามคำแนะนำภาคผนวก ฉ.
11. ก่อนให้เว็บไซต์นี้ เข้าถึงได้จากอินเทอร์เน็ต ข้าพเจ้าได้อ่านและปฏิบัติตามเอกสาร แนวปฏิบัติในการจัดทำเว็บไซต์มหาวิทยาลัยสงขลานครินทร์ ฉบับล่าสุด ที่ประกาศไว้ที่เว็บไซต์สำนักนวัตกรรมการดิจิทัลและระบบอัจฉริยะ มหาวิทยาลัยสงขลานครินทร์ ในหัวข้อ นโยบายไอทีและแนวปฏิบัติ โดยครบถ้วนแล้ว

===== สิ้นสุด รายละเอียด แจ้ง ขอเปิดเว็บไซต์ =====

3. ผู้ดูแลเว็บไซต์ ใช้ PSU Microsoft Teams Chat ติดต่อ songkrant.m หรือ tipaporn.p เพื่อรับรายงาน Nessus Scan เป็นแนวทางดำเนินการแก้ไข และประสานงานการแก้ไขช่องโหว่ จนไม่มีช่องโหว่ Critical, High, Medium หลงเหลืออยู่
4. itoc@psu ได้รับแจ้งจาก songkrant.m หรือ tipaporn.p ว่ารายงาน Nessus ของเว็บไซต์ ไม่มีช่องโหว่ Critical, High, Medium แล้ว จึงจะกำหนดค่าบนไฟร์วอลล์ของมหาวิทยาลัย เพื่อเปิดเว็บไซต์ให้เข้าถึงได้จากอินเทอร์เน็ต
5. เมื่อเว็บไซต์เข้าถึงได้จากอินเทอร์เน็ตแล้ว ผู้ดูแลเว็บไซต์ ตรวจสอบ Public IP Address ได้จาก URL <https://bgp.he.net/dns/ชื่อเว็บไซต์>
6. ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Shodan ว่ามีรายงานช่องโหว่ของเว็บไซต์ ปรากฏสู่สาธารณะหรือไม่ ได้จาก URL <https://www.shodan.io/host/เลข Public IP Address> (ภาคผนวก ก)

7. ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Qualys SSL Server Test ว่ามีการเข้ารหัสข้อมูล (Encryption) เพื่อเพิ่มความปลอดภัยในการสื่อสารผ่านเครือข่าย ตามคำแนะนำ
<https://www.tenable.com/plugins/nessus/156899> ครบถ้วนหรือไม่ ได้จาก URL
<https://www.ssllabs.com/ssltest/analyze.html> (ภาคผนวก ข)
8. ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Security Headers ว่ามี การกำหนดรายละเอียดในส่วนหัวของเว็บไซต์ ครบถ้วนหรือไม่ ได้จาก URL <https://securityheaders.com/> (ภาคผนวก ค)
9. ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ SSL Checker ว่าใบรับรองดิจิทัลได้ติดตั้งถูกต้องหรือไม่ ได้จาก URL <https://www.sslshopper.com/ssl-checker.html> (ภาคผนวก ง)
10. ผู้ดูแลเว็บไซต์ ตรวจสอบว่าในหน้าแรกของเว็บไซต์ มี หมายเลขโทรศัพท์ หรือ อีเมล ที่ผู้ให้บริการสามารถติดต่อสื่อสารกับหน่วยงานได้ (ภาคผนวก จ)
11. ผู้ดูแลเว็บไซต์ ที่โปรแกรมเว็บไซต์ใช้บน OS Linux ให้ทำรายงาน OVAL ตามคำแนะนำ (ภาคผนวก ฉ)
12. ผู้ดูแลเว็บไซต์ ตรวจสอบระบบปฏิบัติการ (Operating System : OS) ตามคำแนะนำ (ภาคผนวก ช)
13. ผู้ดูแลเว็บไซต์ ตรวจสอบการเผยแพร่ข้อมูลส่วนบุคคล ตามคำแนะนำ (ภาคผนวก ซ)
14. ผู้ดูแลเว็บไซต์ จะได้รับรายงาน Nessus สรุปช่องโหว่แบบย่อ ส่งไปถึงอีเมลเตือนละครั้ง หากต้องการเพิ่มอีเมลผู้รับรายงาน หรือหากต้องการรับรายงาน Nessus ฉบับเต็ม ที่มีรายละเอียดที่แสดง CVE ช่องโหว่ และคำแนะนำในการแก้ไขช่องโหว่ หรือเมื่อผู้ดูแลเว็บไซต์มีการปรับปรุงระบบหรือส่วนประกอบเว็บไซต์ หรือมีข้อสงสัยเกี่ยวกับความปลอดภัย สามารถติดต่อ PSU Microsoft Teams Chat songkrant.m หรือ tipaporn.p ให้ทำรายงานเพิ่มเติมได้

ภาคผนวก ก

ก. เครื่องมือตรวจสอบ Shodan รายงานช่องโหว่ของเว็บไซต์ ปรากฏสู่สาธารณะ

คำเป้าหมาย :

ก1 ไม่มี Vulnerability หรือ CVE ปรากฏ
ก2 Server Type ไม่แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์

ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Shodan ว่ามีรายงานช่องโหว่ของเว็บไซต์ ปรากฏสู่สาธารณะหรือไม่ ได้จาก URL

<https://www.shodan.io/host/เลข Public IP Address> *

1. Last Seen จะแสดง ปี ค.ศ. เดือน และวันที่ ล่าสุด ที่ Shodan มีข้อมูล Public IP Address ของเว็บไซต์
2. หาก Shodan ไม่มี ข้อมูล Public IP Address ของเว็บไซต์ จะแสดง No Information
3. หาก Shodan มีข้อมูล Server Type และ Server Type นั้นมีปรากฏช่องโหว่ที่ National Vulnerability Database <https://nvd.nist.gov/> จะแสดงเลข Common Vulnerabilities and Exposures (CVE) และมีคำอธิบายย่อของช่องโหว่ ผู้ดูแลเว็บไซต์ ต้องแก้ไขช่องโหว่
4. ผู้ดูแลเว็บไซต์ “ต้องแก้ไข” Server Type “ไม่ให้แสดงข้อมูล” เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ทำให้แฮกเกอร์ยากที่จะหาช่องโหว่ที่ตรงรุ่นกับระบบ
5. ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์ Shodan_ชื่อเว็บไซต์.psu_ddMon20xx.png เช่น Shodan_diis.psu_4Feb2025.png

* หมายเหตุ * ตรวจสอบ เลข Public IP Address ได้จาก URL <https://bgp.he.net/dns/ชื่อเว็บไซต์>

ภาคผนวก ข

ข. เครื่องมือตรวจสอบ Qualys การเข้ารหัสข้อมูล (Encryption)

ค่าเป้าหมาย : A+

ข1 Configuration > Cipher Suites TLS 1.3 สีเขียว ไม่มี Weak Cipher สีเหลือง ปรากฏ
ข2 Configuration > Cipher Suites TLS 1.2 สีเขียว ไม่มี Weak Cipher สีเหลือง ปรากฏ
ข3 Configuration > Miscellaneous HTTP server signature ไม่แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์

ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Qualys SSL Server Test ว่ามี การเข้ารหัสข้อมูล

(Encryption) เพื่อเพิ่มความปลอดภัยในการสื่อสารผ่านเครือข่าย ตามคำแนะนำ

<https://www.tenable.com/plugins/nessus/156899> ซึ่งให้ใช้เฉพาะ TLS 1.2 และ TLS 1.3

ตรวจสอบการเข้ารหัสข้อมูลที่รับส่งกับเว็บไซต์ได้จาก URL

<https://www.ssllabs.com/ssltest/analyze.html>

1. ให้เลือก Do not show the results on the boards
2. ให้ใส่ชื่อเว็บไซต์ที่ต้องการตรวจสอบ
3. หาก Configuration > Cipher Suites ยังมี Weak Cipher และไม่ได้ใช้เฉพาะ TL 1.2 และ TLS 1.3 ผู้ดูแลเว็บไซต์ ต้องแก้ไข ให้ใช้ Cipher Suites ตามคำแนะนำ
4. หาก Configuration > Miscellaneous HTTP server signature แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ผู้ดูแลเว็บไซต์ “ต้องแก้ไข” ไม่ให้แสดงข้อมูลเกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ทำให้แฮกเกอร์ยากที่จะหาช่องโหว่ที่ตรงรุ่นกับระบบ
5. ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์ SSLlabs_ชื่อเว็บไซต์.psu_Grade_ddMon20xx.png เช่น SSLlabs_diis.psu_A+_4Feb2025.png

ภาคผนวก ค

ค. เครื่องมือตรวจสอบ Security Headers การกำหนดรายละเอียดในส่วนหัวของเว็บไซต์

ค่าเป้าหมาย : A+

ค1 Security Report Summary > Headers: สีเขียว ทั้งหมด

ไม่มี Missing Headers สีแดง และไม่มี Warnings สีเหลือง ปรากฏ

ค2 Raw Headers > server ไม่แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์

ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ Security Headers ว่ามี การกำหนดรายละเอียดในส่วนหัวของเว็บไซต์ ครบถ้วนหรือไม่ ได้จาก URL

<https://securityheaders.com>

1. ให้เลือก Hide results
2. ให้ใส่ชื่อเว็บไซต์ที่ต้องการตรวจสอบ
3. หาก Security Report Summary > Headers ยังมีรายการ สีแดง ผู้ดูแลเว็บไซต์ ต้องแก้ไข ให้เป็น สีเขียว ทั้งหมด ตามคำแนะนำ ในส่วน Missing Headers สีแดง และส่วน Warnings สีเหลือง
4. หาก Raw Headers > server หรือมีส่วนใด แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ผู้ดูแลเว็บไซต์ “ต้องแก้ไข” ไม่ให้แสดงข้อมูลเกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ทำให้แฮกเกอร์ยากที่จะหาช่องโหว่ที่ตรงรุ่นกับระบบ
5. หาก Security Report Summary > Sites แสดง http://ชื่อเว็บไซต์ (Scan again over https) ผู้ดูแลเว็บไซต์ “ต้องแก้ไข” ตามคำแนะนำ HSTS
<https://sysadmin.psu.ac.th/2018/09/12/hardening-your-http-response-headers/>
6. ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์
SecHdr_ชื่อเว็บไซต์.psu_Grade_ddMon20xx.png เช่น
SecHdr_diis.psu_A+_4Feb2025.png

ภาคผนวก ง

ง. เครื่องมือตรวจสอบ SSL Checker การติดตั้งใบรับรองดิจิทัล

คำเป้าหมาย : เครื่องหมายถูก สีเขียว

ง1 The certificate will expire in days มีระยะเวลาอย่างน้อย 7 วัน เพื่อให้ใบรับรองดิจิทัลหมดอายุ ผู้ดูแลเว็บไซต์มีระยะเวลาอย่างน้อย 7 วันในการติดตั้งใบรับรองดิจิทัลใหม่
ง2 ถ้ามี Server Type ต้องไม่แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์
ง3 Certificate Chain แสดงลูกศร สีเขียว ทั้งหมด ไม่มี ลูกศรหัก สีแดง และไม่มี Warnings สีเหลือง ปรากฏ

ผู้ดูแลเว็บไซต์ ใช้เครื่องมือตรวจสอบ SSL Checker ว่าใบรับรองดิจิทัลได้ติดตั้งถูกต้องหรือไม่ ได้จาก URL <https://www.sslshopper.com/ssl-checker.html>

1. ให้ใส่ชื่อเว็บไซต์ที่ต้องการตรวจสอบ
2. หากมี Server Type แสดงข้อมูล เกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ผู้ดูแลเว็บไซต์ “ต้องแก้ไข” ไม่ให้แสดงข้อมูลเกี่ยวกับระบบปฏิบัติการและรุ่นของโปรแกรมเว็บไซต์ ทำให้แฮกเกอร์ยากที่จะหาช่องโหว่ที่ตรงรุ่นกับระบบ
3. หากปรากฏ Certificate Chain แสดงด้วยเครื่องหมาย สีเหลือง หรือ ลูกศรหัก สีแดง ผู้ดูแลเว็บไซต์ ต้องแก้ไขโดยติดตั้งใบรับรองดิจิทัล Intermediate/chain Certificate ให้ถูกต้อง ตามคำแนะนำ ของบริษัทที่พัฒนาโปรแกรมเว็บไซต์ หรือบริษัทที่ออกใบรับรองดิจิทัล ให้แสดงลูกศร สีเขียว ทั้งหมด
4. ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์ CertChain_ชื่อเว็บไซต์.psu_ddMon20xx.png เช่น CertChain_diis.psu_4Feb2025.png

ภาคผนวก จ

จ. รายการตรวจสอบ (Checklist) ประกอบมาตรฐานเว็บไซต์ภาครัฐ เวอร์ชัน 3.0

คำเป้าหมาย : มีข้อมูลแสดงรายละเอียดช่องทางที่ผู้ใช้บริการสามารถติดต่อสื่อสารกับหน่วยงานได้ (Contact us) และมีการประกาศนโยบายครบถ้วน (ดู แนวปฏิบัติ มาตรฐาน และ เกณฑ์ เปรียบเทียบ ข้อที่ 2 ด้านบน)

จ1 เว็บไซต์มี Contact us (อ้างอิง หน้าที่ 5 มาตรฐานเว็บไซต์ภาครัฐ ver.3)
จ2 เว็บไซต์มี หมายเลขโทรศัพท์ ที่ผู้ใช้บริการสามารถติดต่อสื่อสารกับหน่วยงานได้
จ3 เว็บไซต์มี นโยบายเว็บไซต์ (อ้างอิง 10.1 หน้าที่ 22 และ ภาคผนวก ค. หน้าที่ 32-36 มาตรฐานเว็บไซต์ภาครัฐ ver.3)
จ4 เว็บไซต์มี นโยบายการคุ้มครองข้อมูลส่วนบุคคล และ นโยบายคุกกี้ (อ้างอิง 10.2 หน้าที่ 22 และ ภาคผนวก ค. หน้าที่ 37-40 มาตรฐานเว็บไซต์ภาครัฐ ver.3)
จ5 เว็บไซต์มี นโยบายการรักษาความมั่นคงปลอดภัยเว็บไซต์ (อ้างอิง 10.3 หน้าที่ 23 และ ภาคผนวก ค. หน้าที่ 40-43 มาตรฐานเว็บไซต์ภาครัฐ ver.3)

ผู้ดูแลเว็บไซต์ “ต้องจัดทำให้มี” ข้อมูลแสดงรายละเอียดช่องทางที่ผู้ใช้บริการสามารถติดต่อสื่อสารกับหน่วยงานได้ (Contact us) และมีการประกาศนโยบายครบถ้วน โดยคำเป้าหมาย จ1 ถึง จ5 เป็นข้อกำหนดขั้นต่ำที่ต้องปรากฏใน เว็บไซต์ ตามแนวปฏิบัติในการจัดทำเว็บไซต์

มหาวิทยาลัยสงขลานครินทร์

ทั้งนี้หากเว็บไซต์ส่วนงานมีรายละเอียดบริการที่เกี่ยวข้องกับธุรกรรมอิเล็กทรอนิกส์เพิ่มเติม ผู้ดูแลเว็บไซต์ ต้องดำเนินการเพิ่มเติมในข้ออื่น ๆ ที่เกี่ยวข้อง เพื่อให้เป็นไปตาม มาตรฐานเว็บไซต์ภาครัฐ ver.3 จนครบถ้วน

ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์ Contact_ชื่อเว็บไซต์.psu_ddMon20xx.png เช่น Contact_diis.psu_4Feb2025.png

ภาคผนวก จ

จ. รายงาน OVAL (Open Vulnerability and Assessment Language) สำหรับ Linux

คำเป้าหมาย : OS ของเว็บไซต์ “ไม่มีช่องโหว่” ที่ยังไม่ได้แก้ไข (#X = 0)

ฉ1 OS ของเว็บไซต์ “ไม่มีช่องโหว่” ที่ยังไม่ได้แก้ไข (#X = 0)

ผู้ดูแลเว็บไซต์ ทุกๆ OS “ต้องปรับปรุง อัปเดต” OS และส่วนประกอบโปรแกรมต่างๆ ตามที่ผู้ผลิต OS แนะนำ อย่างสม่ำเสมอเพื่อไม่ให้มีช่องโหว่

สำหรับ OS ที่เป็น Linux ให้ทำรายงาน OVAL ซึ่งแสดงรายการแก้ไขช่องโหว่ ตาม NIST NVD CVE ใช้เปรียบเทียบกับ CVE ตามรายงาน Nessus

1. Debian สร้างรายงาน OVAL ตามคำแนะนำ

<https://sysadmin.psu.ac.th/2024/01/02/debian-oval/>

ไฟล์สำหรับตรวจสอบ Debian OVAL ล่าสุดอยู่ที่ลิงก์

<https://www.debian.org/security/oval/>

2. Ubuntu สร้างรายงาน OVAL ตามคำแนะนำ

<https://sysadmin.psu.ac.th/2023/02/14/ubuntu-oval/>

ไฟล์สำหรับตรวจสอบ Ubuntu OVAL ให้ใช้แบบ(Type) CVE ตามรุ่นของ OS ล่าสุด อยู่ที่ลิงก์

<https://security-metadata.canonical.com/oval/>

3. Windows และ OS อื่นๆ ที่ไม่มีรายงาน OVAL แนะนำให้ใช้ CIS Benchmark

<https://www.cisecurity.org/cis-benchmarks>

4. ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ .html โดยกำหนดชื่อไฟล์

OVAL_ชื่อเว็บไซต์.psu_ddMon20xx.html เช่น OVAL_diis.psu_4Feb2025.html

ภาคผนวก ข

ข. ตรวจสอบระบบปฏิบัติการ (Operating System : OS)

คำเป้าหมาย : OS ของเครื่องบริการเว็บไซต์ใช้รุ่นที่บริษัทผู้ผลิตยังคงให้การสนับสนุนการแก้ไขช่องโหว่ปรับปรุงความปลอดภัยที่ยาวนานอย่างน้อย 2 ปี

ข1 OS ของเครื่องบริการเว็บไซต์ใช้รุ่นที่บริษัทผู้ผลิตยังคงให้การสนับสนุนการแก้ไขช่องโหว่ปรับปรุงความปลอดภัยที่ยาวนานอย่างน้อย 2 ปี

ผู้ดูแลเว็บไซต์ ทุกๆ OS “ต้องปรับปรุง อัปเดต” OS ของเครื่องบริการเว็บไซต์และส่วนประกอบโปรแกรมต่างๆ ตามที่ผู้ผลิต OS แนะนำ อย่างสม่ำเสมอเพื่อไม่ให้มีช่องโหว่

Debian 12 (Bookworm) — current “stable” release, until 30Jun2028

Debian 11 (Bullseye) — current “oldstable” release, until 31Aug2026

Ubuntu 24.04 LTS (Noble Numbat) until June 2029

Ubuntu 22.04 LTS (Jammy Jellyfish) until June 2027

Windows Server 2025 LTSC until 9Oct2029

Windows Server 2022 LTSC until 13Oct2026 <- คงเหลือการสนับสนุนไม่ถึง 2 ปี

หรือหากเป็น OS อื่นก็ต้องแสดงเว็บไซต์อ้างอิงการสนับสนุนการแก้ไขช่องโหว่ปรับปรุงความปลอดภัยไปอีกอย่างน้อย 2 ปี

อ้างอิงจาก

<https://www.debian.org/releases/>

<https://wiki.ubuntu.com/Releases>

<https://learn.microsoft.com/en-us/windows-server/get-started/windows-server-release-info>

ผู้ดูแลเว็บไซต์ส่งหลักฐานประกอบการตรวจสอบเป็นไฟล์ภาพ .png โดยกำหนดชื่อไฟล์

OS_ชื่อเว็บไซต์.psu_ddMon20xx.png เช่น OS_diis.psu_4Feb2025.png

ภาคผนวก ข

ข. ตรวจสอบการเผยแพร่ข้อมูลส่วนบุคคล

ค่าเป้าหมาย : ไม่มี การเผยแพร่ข้อมูลส่วนบุคคลบนเว็บไซต์

นโยบายคุ้มครองข้อมูลส่วนบุคคล (Privacy Policy)

ข้อ ๘ มหาวิทยาลัยจัดให้มีมาตรการรักษาความมั่นคงปลอดภัยของข้อมูลส่วนบุคคลที่เหมาะสม

<https://gdpr.psu.ac.th/pdf/GDPR1TH.pdf> 10May2023

ประกาศมหาวิทยาลัยสงขลานครินทร์ว่าด้วยการคุ้มครองข้อมูลส่วนบุคคล (Privacy Notice)

<https://gdpr.psu.ac.th/pdf/privacy-notice.pdf> 27May2024

ขอความร่วมมือ ตรวจสอบการเผยแพร่ข้อมูลส่วนบุคคลบนเว็บไซต์และสื่อโซเชียลของหน่วยงาน

<https://diis.psu.ac.th/general-news/psudiis30012567-2>

ภาคผนวก ณ

ณ. ตรวจสอบ Security Scorecard

ค่าเป้าหมาย : A

เกณฑ์เปรียบเทียบ Security Scorecard จาก สกมช. โดยระบบ Proactive Cyber Watch (PCW) รายงานสรุปภัยคุกคามทางไซเบอร์ของหน่วยงาน (ระบบ Attack Surface Management) ซึ่งเป็นส่วนของโครงการระบบตรวจจับพฤติกรรมและวิเคราะห์ข้อมูลอาชญากรรมทางไซเบอร์เชิงรุกสำหรับหน่วยงานโครงสร้างพื้นฐานสำคัญ ทางสารสนเทศ และหน่วยงานภาครัฐ มีการจัดส่งรายงานประจำเดือนมาให้มหาวิทยาลัยซึ่งได้เข้าร่วมโครงการ โดยรายงานอ้างอิงจาก

<https://securityscorecard.com/>

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
1	Month เดือนที่ได้รับ รายงาน	Overall Score from 100	Application Security ความปลอดภัยของแอปพลิเคชัน				Endpoint Security ความปลอดภัยของอุปกรณ์ ปลายทาง				IP Reputation ความน่าเชื่อถือของไอพี				Network Security ความปลอดภัยของเครือข่าย				Patching Cadence การอัปเดตแพตช์แก้ไขช่องโหว่			
2	Risk Level		H	M	L	Score	H	M	L	Score	H	M	L	Score	H	M	L	Score	H	M	L	Score
3	04-Feb-24	49	117	783	720	3	2	0	0	81	0	0	0	100	114	302	266	16	11,409	6,950	450	7
4	Nov-24	47	139	0	1,599	46	2	0	0	86	0	0	12	84	31	62	305	48	0	1,372	9,708	48
5	Dec-24	47	143	0	1,378	45	3	0	0	83	1	0	11	68	32	35	271	49	0	989	8,272	47
6																						
7	Compared with previous month ---->						Red - Getting worse				Green - Getting better				Black - Unchanged							
8	Risk Level High (H), Medium (M), Low (L) show number of security issue count at each level, one server may have more than 1 security issues																					
9	Score : Higher is better, 100 Maximum																					

ซึ่งเป็นการตรวจสอบในภาพรวมขององค์กรภายใต้ชื่อโดเมน psu.ac.th โดย ม.อ.ได้ตรวจสอบครั้งแรกเมื่อวันที่ 4 ก.พ. 2567 ก่อนที่จะเข้าร่วมโครงการกับ สกมช. โดย Security Scorecard มี 10หัวข้อในการตรวจสอบ ซึ่ง ม.อ. ได้คะแนนเต็ม 100 ใน 5 หัวข้อต่อไปนี้

1. Cubit Score คะแนนประเมินความปลอดภัย
2. DNS Health ความปลอดภัยของระบบโดเมนเนม
3. Hacker Chatter การพูดคุยเกี่ยวกับองค์กรของแฮกเกอร์
4. Information Leak การรั่วไหลของข้อมูล
5. Social Engineering การหลอกให้ผู้ใช้ตกเป็นเหยื่อ

ยังคงเหลือ 5 หัวข้อตามรูปข้างบนที่ ม.อ. ยังต้องปรับปรุงผ่านความร่วมมือจากทุกๆ ส่วนงานในการจัดทำเว็บไซต์ให้มีความมั่นคงปลอดภัย “ผ่าน” ทุกข้อตามภาคผนวกต่างๆ ของแนวปฏิบัตินี้ เพื่อให้ผลการตรวจสอบเปลี่ยนแปลงจาก F ไปสู่ A

เฉพาะผู้ใช้ Google Chrome Desktop จะสามารถติดตั้ง SecurityScorecard Extension โดยเปิดลิงก์

<https://chromewebstore.google.com/>

และ Search Extension ชื่อ SecurityScorecard

แล้วติดตั้งใช้งาน เพื่อดูคะแนนขององค์กรต่างๆ ผ่านการเปิดหน้าเว็บไซต์ได้ ซึ่งข้อมูลบาง

สถาบันการศึกษาปรากฏตามตาราง

	A	B	C	D	E
1	Score	Domain	Industry	Footprint	Followers
2	B	mit.edu	Education	2.45M IPs	Monitored by 1,389 companies
3	D	stanford.edu	Education	409K IPs	Monitored by 272 companies
4	F	kmitl.ac.th	Education	5.8K IPs	Monitored by 3 companies
5	F	tu.ac.th	Education	4.3K IPs	Monitored by 4 companies
6	F	sut.ac.th	Education	2.6K IPs	Monitored by 7 companies
7	F	chula.ac.th	Education	2.5K IPs	Monitored by 39 companies
8	F	psu.ac.th	Education	2.1K IPs	Monitored by 8 companies
9	F	mahidol.ac.th	Education	806 IPs	Monitored by 16 companies
10	F	kku.ac.th	Education	792 IPs	Monitored by 4 companies
11	F	cmu.ac.th	Retail	721 IPs	Monitored by 11 companies
12	D	ntu.edu.sg	Education	578 IPs	Monitored by 31 companies
13	F	stou.ac.th	Education	443 IPs	Monitored by 1 companies
14	F	swu.ac.th	Education	170 IPs	Monitored by 1 companies
15	F	wu.ac.th	Education	137 IPs	Monitored by 2 companies
16	F	skru.ac.th	Unknown	119 IPs	Monitored by 1 companies
17	F	bu.ac.th	No Info.	No Info.	No Info.
18	F	buu.ac.th	No Info.	No Info.	No Info.
19	F	kmutt.ac.th	No Info.	No Info.	No Info.
20	C	ku.ac.th	No Info.	No Info.	No Info.
21	C	mfu.ac.th	No Info.	No Info.	No Info.
22	C	nus.edu.sg	No Info.	No Info.	No Info.
23	F	rmutsu.ac.th	No Info.	No Info.	No Info.
24	D	ru.ac.th	No Info.	No Info.	No Info.
25	D	su.ac.th	No Info.	No Info.	No Info.
26	D	spu.ac.th	No Info.	No Info.	No Info.
27	F	tsu.ac.th	No Info.	No Info.	No Info.
28	D	utcc.ac.th	No Info.	No Info.	No Info.
29	D	nida.ac.th	No Info.	No Info.	No Info.
30	As 4Feb2025				